

CS-5.1 Secrets in Code

Status: Draft

Definitions

Version Control System (VCS)

A system for storing application source code and tracking changes to it over time. The full source code of applications is stored in a VCS, as well as any additions or removals to that source code.

Secret

A piece of data that controls access to a system or that can encrypt/decrypt another piece of data. It could be a password, private key, symmetric encryption key, database connection string, an API key, an initialization vector (IV) or salt, a username/password pair, a hashed password, etc.

Control Objective

- Ensure that the company's people, processes, and technology systems are prepared to perform secure software development.
- Protecting all components of the company's software from tampering and unauthorized access.
- Producing well-secured software with minimal security vulnerabilities in its releases.
- Detecting hard-coded secrets before they are saved to version control systems.
- Detecting and removing secrets from version control systems.
- Ensuring that secrets are properly created, stored, and destroyed.

Control Validation

- Software applications must be scanned with secrets scanning tools before software is released.
- Discovered hardcoded secrets must be tracked and development teams must remove them from the VCS considering the SLAs for vulnerabilities.
- Discovered hardcoded secrets must be rotated immediately, as removing a secret from the VCS will not delete it from the changelog and it can be recovered trivially.
- Proper secrets management solutions (i.e. CyberArk Conjur) must be used to manage secrets within software applications.